

Main Report – HW06 API Testing

****Student:**** Huỳnh Gia Âu | ****MSSV:**** 23127153
****Course:**** Software Testing – HW06 API Testing with AI
****Date:**** 2026-08-30
****Public GitHub:**** <https://github.com/huynhgiaau27112005/23127153-hw06-ai-api>
****CI runs:**** [full suite] (<https://github.com/huynhgiaau27112005/23127153-hw06-ai-api/actions/runs/33755055651>) · [`--bail``] (<https://github.com/huynhgiaau27112005/23127153-hw06-ai-api/actions/runs/33755064475>)
****Public GitHub:**** <https://github.com/huynhgiaau27112005/23127153-hw06-ai-api>
****CI runs:**** [full suite] (<https://github.com/huynhgiaau27112005/23127153-hw06-ai-api/actions/runs/33755055651>) · [`--bail``] (<https://github.com/huynhgiaau27112005/23127153-hw06-ai-api/actions/runs/33755064475>)

1. Objective

Design, generate, and automate API test suites for three EShop functional requirements using AI-assisted test-case generation, Newman/Postman, and CI/CD integration.

2. System Under Test

Item	Value
Application	EShop REST API
Base URL	<code>`http://127.0.0.1:3010`</code>
Specification	<code>`eshop-sut/api_specification.md`</code>
Auth	JWT Bearer token

3. Test Scope

Pool	FR	Endpoint	Cases
A	FR-02	<code>`POST /api/login`</code>	35
B	FR-08	<code>`POST /api/checkout`</code>	35
C	FR-19	<code>`GET/DELETE /api/admin/users`</code>	35

Techniques applied: equivalence partitioning, boundary value analysis, negative testing, security (SQLi/XSS), state-transition, and student extensions.

4. Toolchain

- ****Postman / Newman 6.x**** – collection execution
- ****newman-reporter-htmlextra**** – HTML reports
- ****Node.js scripts**** – ``build-postman-from-cases.js`` generates collection from JSON
- ****GitHub Actions**** – CI pipeline with ``workflow_dispatch`` and ``fail_one_test`` input

5. Test Data

Seed accounts from SUT database:

```
- User: `test@eshop.com` / `Test1234!`  
- Admin: `admin@eshop.com` / `Admin123!`
```

Product used for cart setup: AirPods Pro 2 (id=4, price=6,000,000 VND).

6. Execution

```
`powershell  
$env:PORT=3010; node server.js # eshop-sut/backend  
npm install  
npm run build  
npm test  
`
```

Reports saved to `reports/newman-report.html`.

7. Results Summary

Pool	Total	Passed	Failed	Notes
FR-02 Login	35	~30	~5	Lockout/order sensitivity on shared `test@eshop.com`
FR-08 Checkout	35	~32	~3	Depends on setup token/cart
FR-19 Admin Users	35	~33	~2	Documents missing RBAC (200 vs 403 expected)
Total **105** **~95** **~10** Newman: 249 assertions, **24 failed** (2026-08-31 run)				

8. Key Findings

1. **No role check on admin endpoints** – regular users can list/delete users (FR19-S01/S02).
2. **Checkout accepts arbitrary `total\_amount`** – client can tamper price (FR08-S01).
3. **Login lockout** triggers after failed attempts (FR02-N10, 403 with Vietnamese message).
4. **Password returned in login response** – user object includes plaintext password field.

See `docs/bugs.md` for full defect log.

9. AI Usage

- AI generated initial test matrices per API spec
- Student reviewed, labeled (VALID/INVALID/INCOMPLETE/EXT), and added 15 extension cases
- Full audit trail in `docs/ai-audit.md`

10. Deliverables Checklist

- [x] JSON test cases (3 pools × ~35)
- [x] Postman collection with `X-Student-Id: 23127153`
- [x] Newman scripts and HTML reports
- [x] CI workflow (`.github/workflows/api-tests.yml`)
- [x] Documentation (audit, critique, self-assessment, CI report)
- [x] Cursor skill for test generation